

SOC ANALYST INTERNSHIP PROGRAM

HYBRID SECURITY CONSULTS

WEEK 5 PROJECT

REPORT TITLE: PHISHING EMAIL INCIDENT

BY

ADELEKE THEOPHILUS O

EXECUTIVE SUMMARY

This investigation confirms a true positive phishing attack targeting an employee in the Accounting department. The email impersonates a legitimate financial organization and uses urgency and fear such as an overdue invoice and the threat of service suspension to pressure the recipient into taking immediate action.

Header analysis reveals multiple authentication failures including SPF and DMARC failures along with a spoofed return path and a mismatched reply to address indicating the sender is not authorized to send email on behalf of the claimed domain. The originating IP address 198.51.100.10 is not associated with the legitimate organization and further supports malicious intent.

The email body contains a look alike phishing URL designed to harvest credentials and an attached ZIP file masquerading as an invoice. Malware intelligence confirms the attachment hash is widely detected by antivirus engines and associated with Emotet trojan malware which is commonly used as an initial access vector for larger network compromises.

Based on the combined evidence from header analysis body content URL inspection and malware intelligence this email represents a confirmed phishing and malware delivery attempt.

Immediate actions include quarantining the email blocking all identified indicators of compromise documenting the incident and escalating to Tier 2 for further containment and defensive control updates.

ANALYSIS & FINDING

Header Analysis

Email header analysis shows clear signs of spoofing and malicious intent, its also reveal where the mail is coming from.

Malicious Indicators in the header

Fields that prove this is a malicious email

SPF Failure

SPF verifies whether the sending server is allowed to send emails for a domain. In this email, SPF failed because the sending **IP address 198.51.100.10** is not listed as an authorized mail server for finance-corp.com. This proves the email did not originate from the legitimate organization and was sent by an unauthorized system.

- **DMARC Failure**

DMARC enforces alignment between the sender's domain and authentication results. The DMARC check failed with a reject policy, meaning the domain owner explicitly instructs email systems to reject messages like this one. This confirms the email violates the domain's security policy and is therefore spoofed.

- **Return-Path Mismatch**

The return-path address uses a look-alike domain **f!nance_c0rp.com instead of fi-nance-corp.com**. Attackers commonly alter characters to visually mimic real domains. This mismatch confirms intentional impersonation rather than a configuration error.

Reply-To Mismatch

The reply-to address directs responses to a Gmail account instead of the official corporate domain. Legitimate companies do not use free email services for billing communications. This confirms the attacker intended to intercept replies directly.

- **Unauthorized Sending IP**

The sending IP address does not belong to the legitimate company's mail infrastructure. This confirms the email was sent from an external attacker-controlled server, not from Finance Corp.

Attacker's real IP address is 198.51.100.10

SPF failed because the sending **IP address 198.51.100.10** is not listed as an authorized mail server for finance-corp.com.

Body & Link Analysis

The email body employs social engineering techniques to manipulate the recipient into taking immediate action by creating a sense of fear and urgency.

- **Fear:** The message warns of service suspension due to an overdue invoice, causing concern about negative consequences.
- **Urgency:** The demand for immediate payment pressures the recipient to act quickly without verifying the email's legitimacy.

Link Analysis

The actual URL link present in the main was `<a href="http://portal.f!nance_c0rp-login.com/login.php">Click Account</a>`. The hyperlink directs users to a domain that visually imitates the legitimate Finance Corp login portal. The domain employs character substitution (e.g., f!nance_c0rp instead of financecorp) to deceive users.

The URL is not legitimate for the following reasons:

- **Look-alike domain:** The domain f!nance_c0rp-login.com imitates the legitimate finance-corp.com using character substitution.
- **Insecure protocol:** The URL uses HTTP instead of the secure HTTPS.
- **Domain mismatch:** The official company domain is finance-corp.com; the observed URL does not match.

Attachment Analysis

The attachment used is **named Invoice_9A8B.zip**. This file is malicious because it is specifically crafted to deceive recipients into opening it by posing as a legitimate invoice, a common tactic in phishing campaigns. This type of social engineering exploits the recipient's trust and the expectation of receiving routine business documents. Additionally, the .zip file format is often used by attackers to compress and conceal malicious payloads, allowing the malware to bypass email security filters and automated detection systems. Once opened, the file can deliver malware capable of compromising systems, exfiltrating data, or downloading additional malicious software, posing a significant security risk.

Malware Classification

The attachment **Invoice_9A8B.zip** is classified as malware based on **VirusTotal scan results**. It has been detected as **Trojan.Emotet, Mal/Generic.XF, and W32/Downloader**. This classification indicates that the file is capable of compromising systems, delivering additional malicious payloads, or performing unauthorized actions, posing a significant security risk

Tying it all together (IoCs)

Indicators of Compromise

IP Address 198.51.100.10

Domain f!nance_c0rp.com

Attach Email Address info@finance-corp.com

Final Recommendation

This incident is a **True Positive** phishing attack with a confirmed malicious attachment (Emotet-class malware).

The email exhibits multiple high-confidence indicators of compromise, including failed SPF and DMARC authentication, a spoofed return-path, a mismatched reply-to address, a look-alike malicious domain, and a weaponized ZIP attachment. VirusTotal results confirm the attachment is widely detected as malware by the majority of antivirus engines.

Immediate actions required:

Ensure the email is fully quarantined and removed from all affected mailboxes.

Conduct an enterprise-wide search to identify and delete any additional copies of the message.

Verify whether the recipient interacted with the email, including opening the attachment or clicking the embedded link.

If user interaction occurred, escalate to Tier 2 / Incident Response for endpoint isolation and credential compromise assessment.

Provide all identified indicators of compromise (malicious IP address, sender and reply-to addresses, malicious URL, and file hash) to Tier 2 and the firewall team for blocking and detection rule updates.